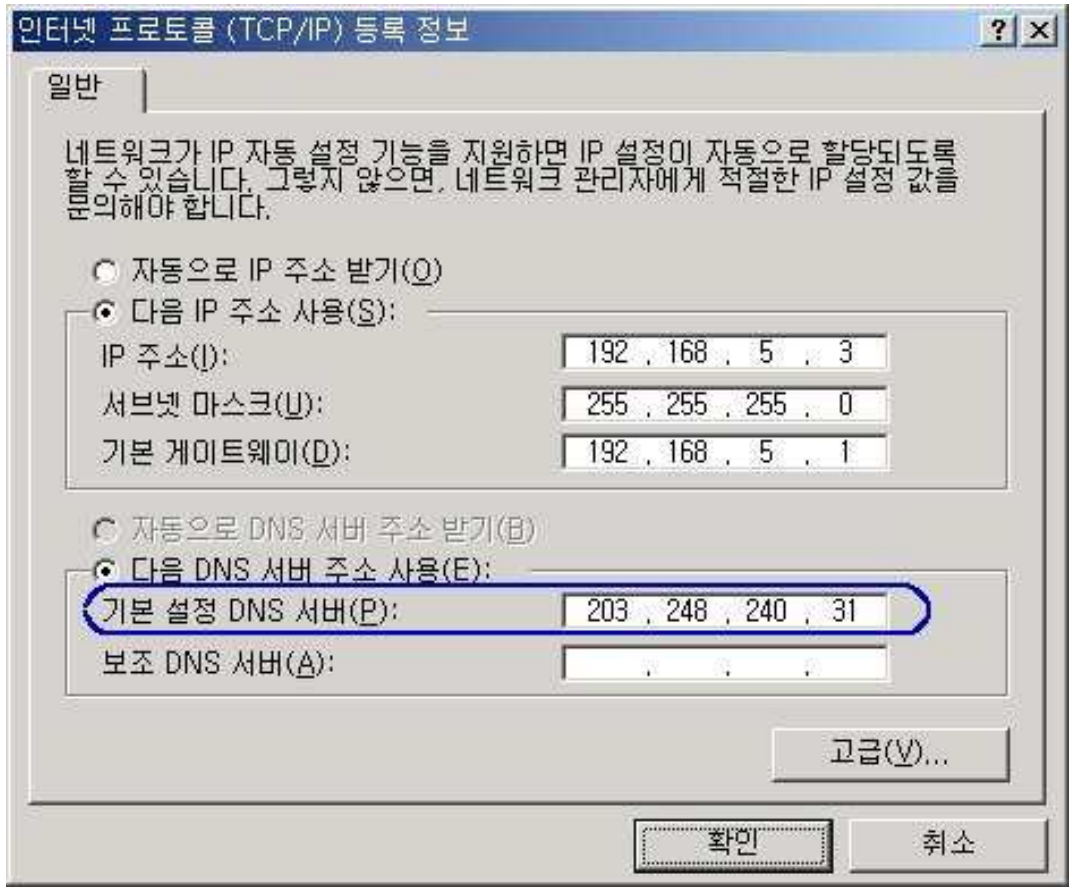
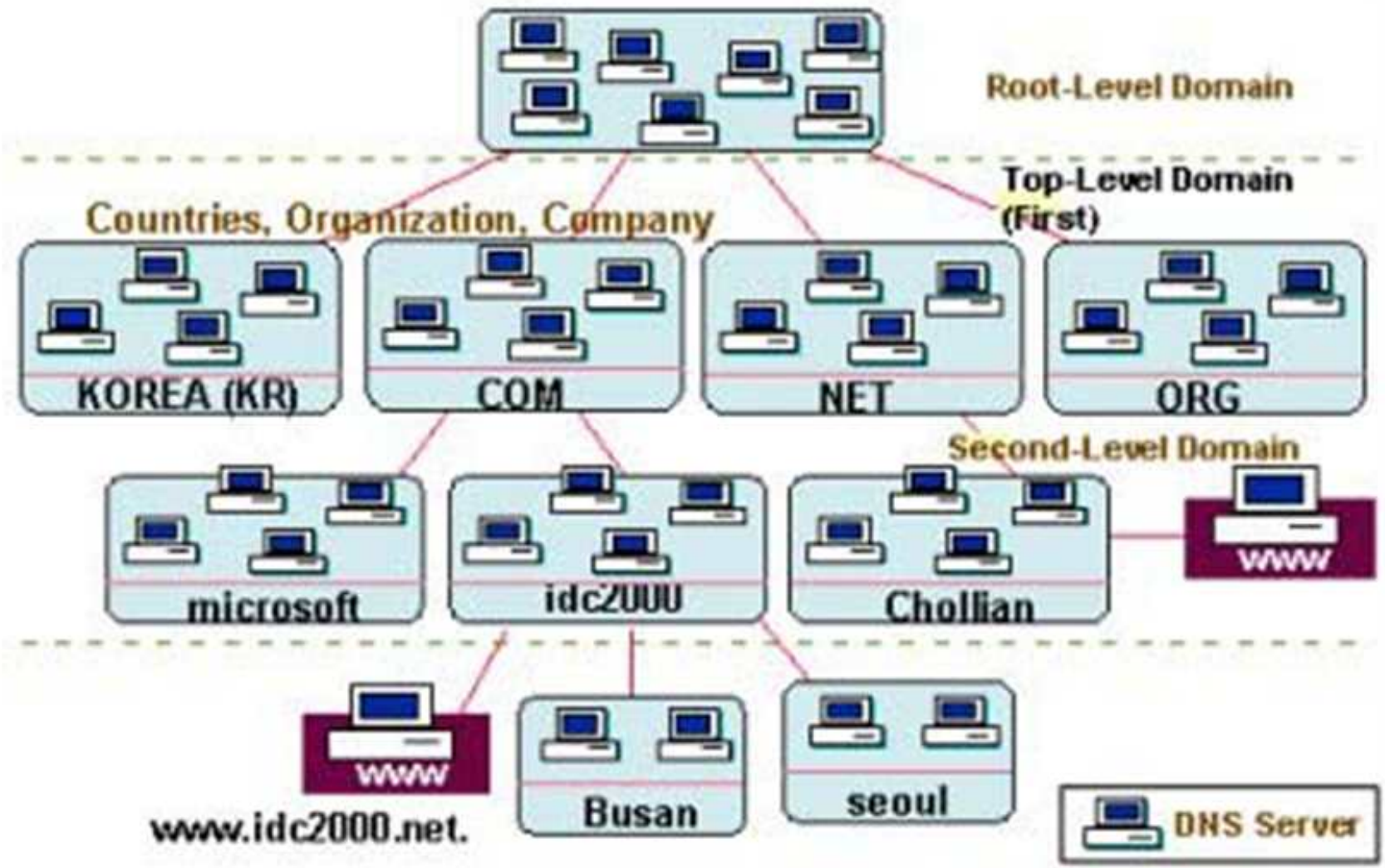
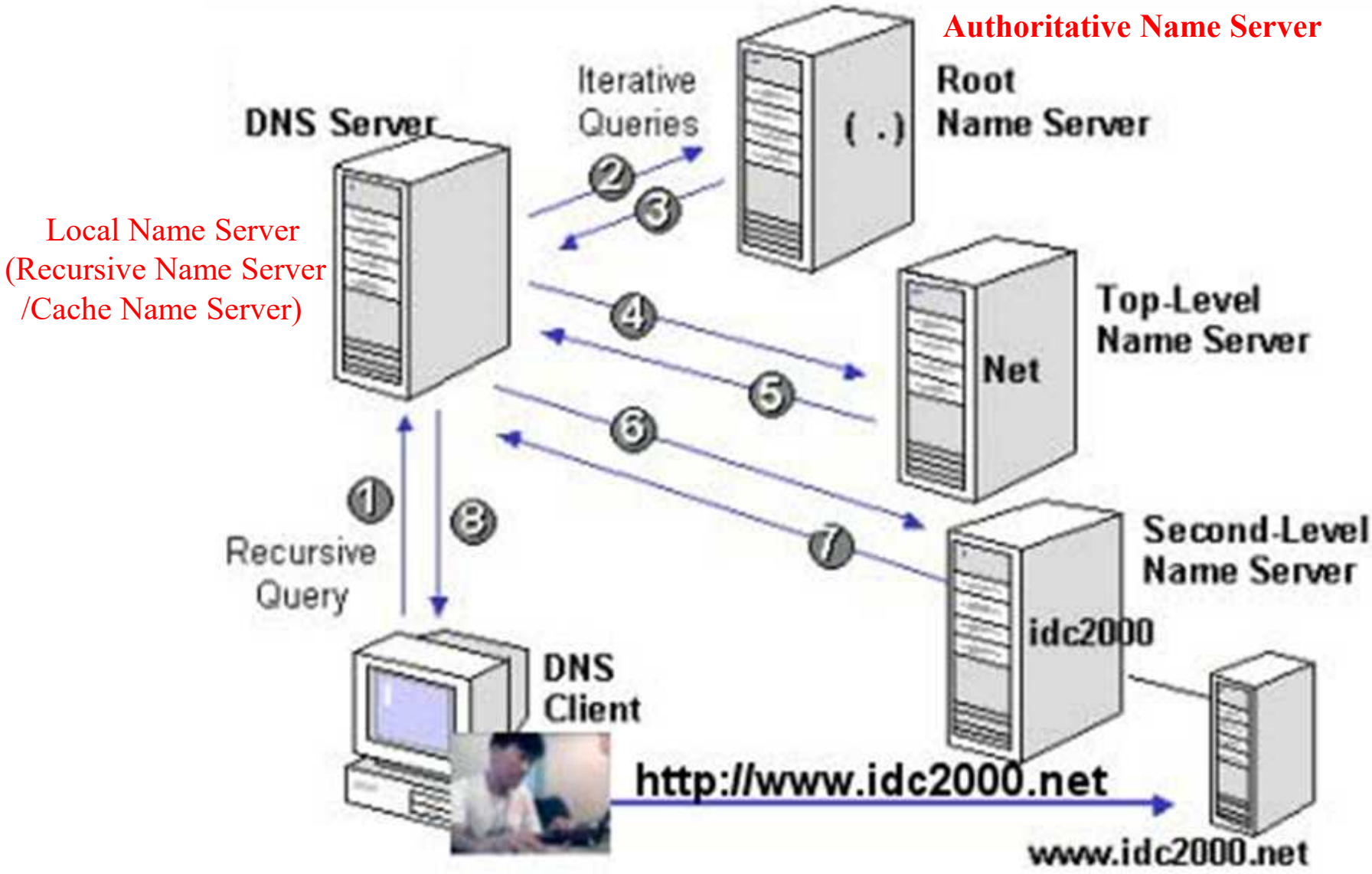
DNS(Domain Name System)



DNS의 구조 및 프로세스



DNS Name Resolution



- **Local Name Server**

  - Recursive Name Server 또는 Cache Name Server

  - 사용자 호스트로부터 질의가 들어오면 자신의 캐시에 저장된 정보 또는 반복적 질의 통해 그 결과를 사용자 호스트에 응답

  - 일반적으로 ISP업체가 제공(예) KT(kns.kornet.net/168.126.63.1)

- **Master Name Server**

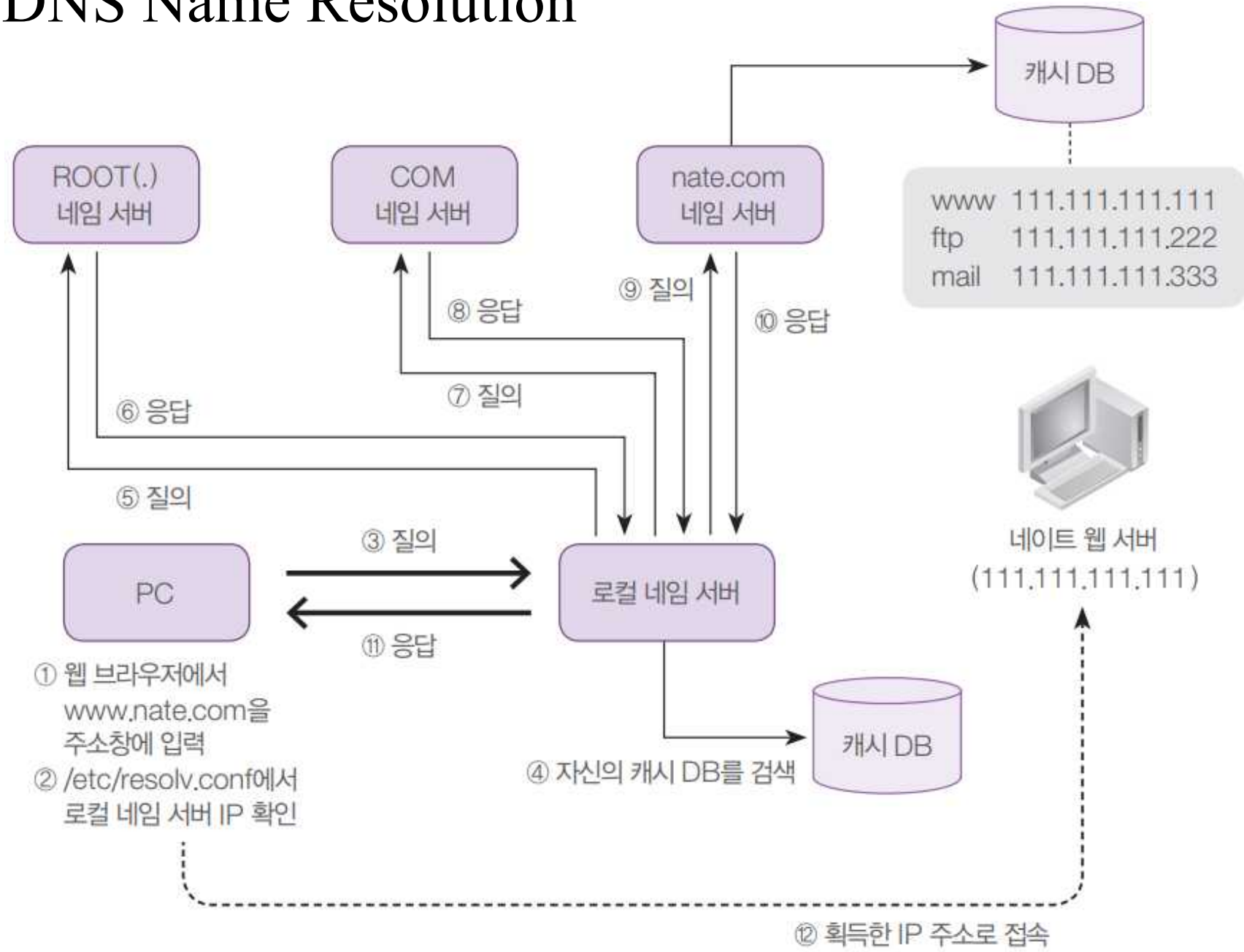
  - 특정 도메인에 대한 정보를 관리하면서 해당 도메인에 대한 질의만 응답하는 네임서버

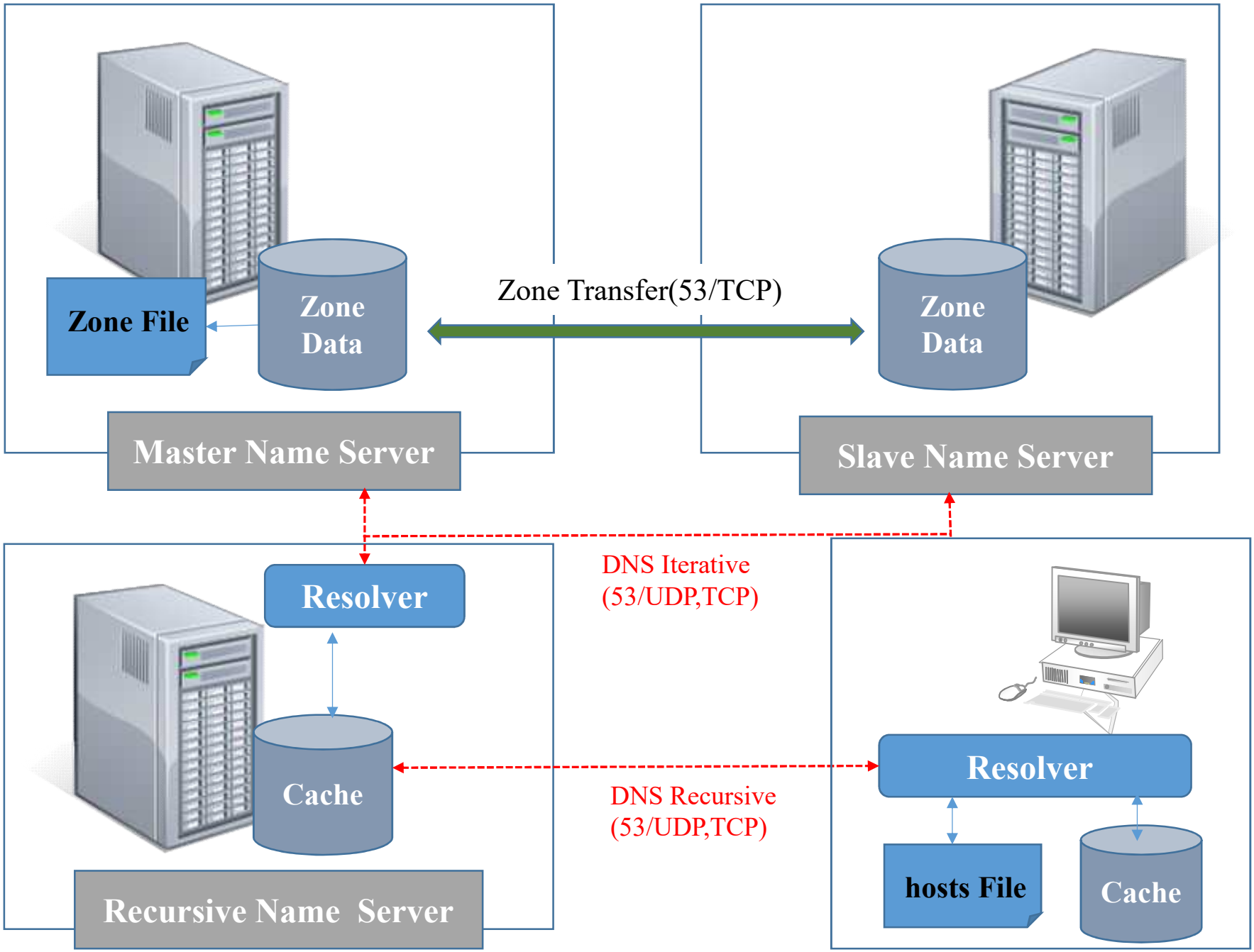
  - 각 회사/사이트별로 자신의 도메인을 관리하는 DNS 서버

  - 네임서버가 관리하는 도메인 영역을 존(zone)이라 함

  - Zone file : 관리 도메인에 대한 정보를 담고 있는 파일

DNS Name Resolution



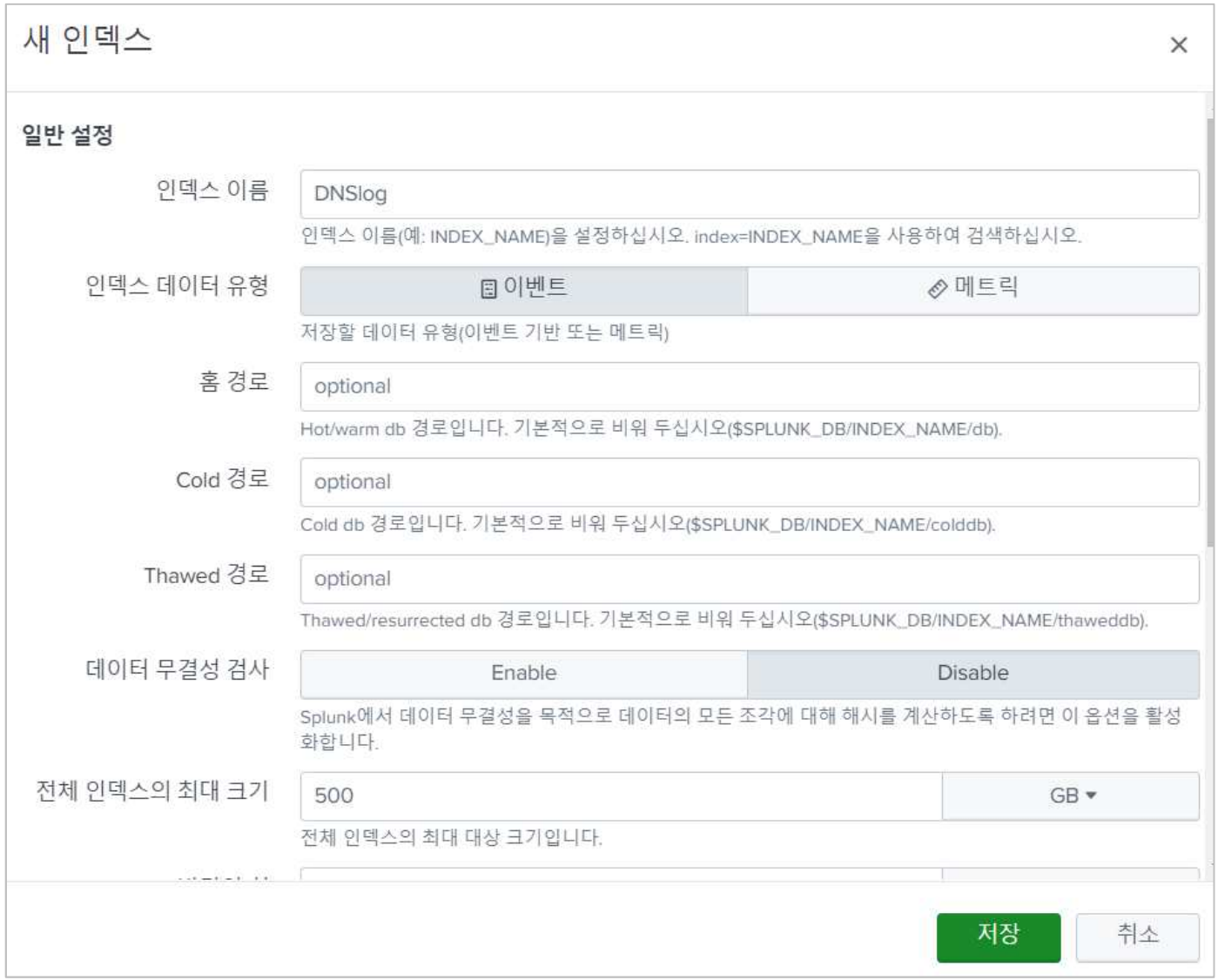

Zone File
Zone Data
Zone Transfer(53/TCP)
Zone Data
Master Name Server
Slave Name Server
DNS Iterative
(53/UDP,TCP)
Resolver
Cache
DNS Recursive
(53/UDP,TCP)
Resolver
hosts File
Cache
Recursive Name Server

DNS 로그 필드

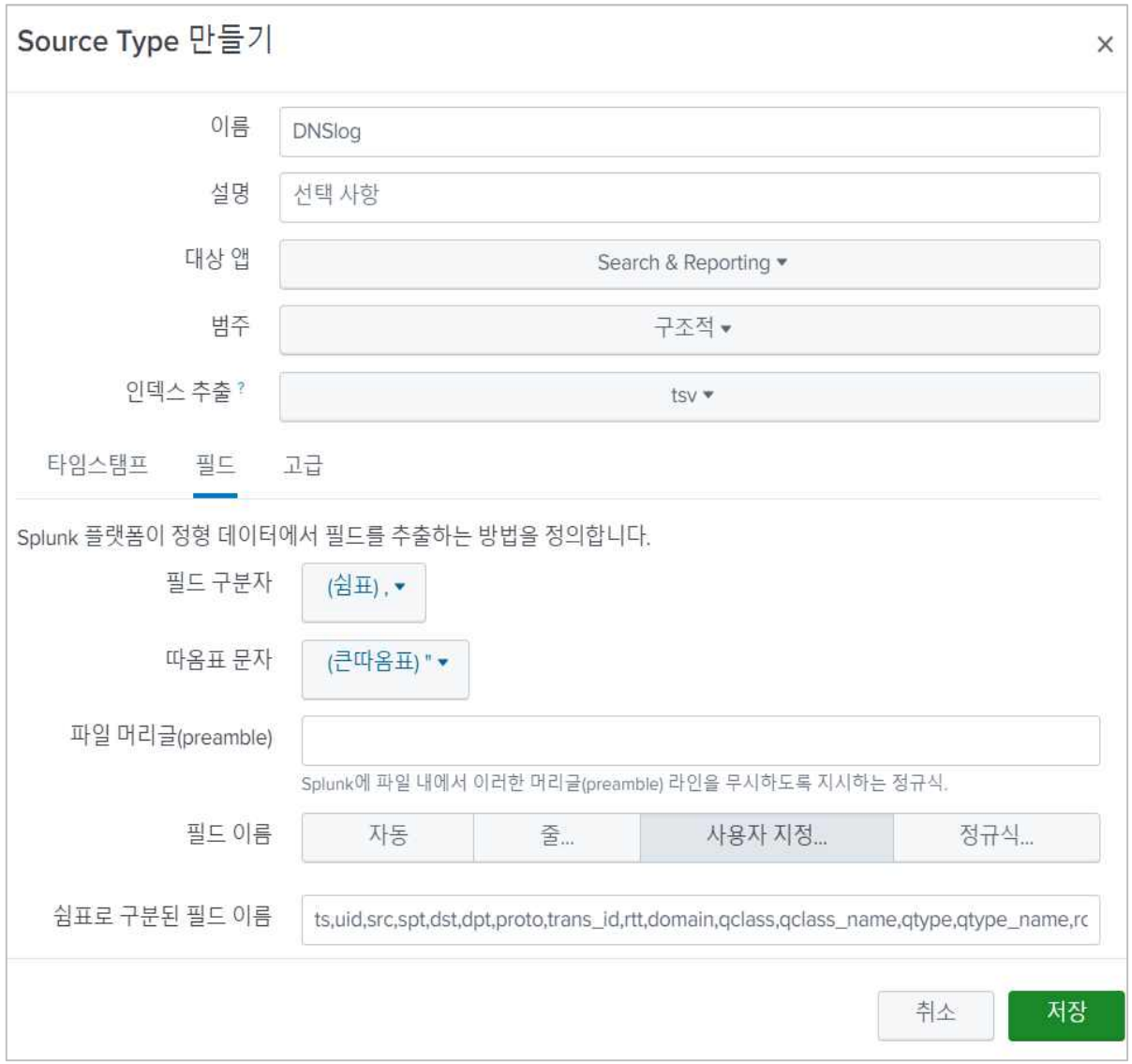
필드명	필드 설명
ts	시간정보로 Unix시간으로 표시
Uid	로그에 할당된 ID
Id.orig_h	송신지 IP주소
Id.orig_p	송신지 Port번호
Id.resp_h	수신지 IP 주소
Id.resp_p	수신지 Port 번호
Protocol	사용 프로토콜
trans_id	질의와 응답을 연결하는 ID
Rtt	응답시간
query	도메인질의내용

필드명	필드 설명
Qclass	질의클래스
Qclass_name	질의클래스 이름
Qtype	질의형식
Qtype_name	질의형식이름
rcode	답변코드
Rcode_name	답변코드이름
AA	인증서버답변여부
TC	전체질의가 잘렸는지 여부
RD	재귀질의 요청여부
RA	재귀질의 가능여부
Z	예약된 필드로 사용하지 않음
Answers	DNS서버에서 반환한 답변내역
TTLs	반환한 도메인의 TTL값
Reject	질의가 거부됐는지 판단

❶ 설정 > 데이터 > 인덱스 > 새로 만들기 인덱스



❷ 설정 > 데이터 > Source Type > 새로 만들기 Source Type



데이터 추가
원본 선택
입력 설정
검토
완료
< 뒤로
제출 >
검토
입력 유형 ..... 업로드된 파일
파일 이름 ..... dns.zip
Source Type ..... DNSlog
호스트 DESKTOP-T79SQGC
인덱스 ..... dnslog

DNS 네트워크 현황 분석 항목

❶ Top 10 도메인 현황

❷ Top 10 도메인 요청 IP 현황

❸ 도메인 응답코드 현황

❶ Top 10 도메인 현황

- 사용자가 가방 많이 접속한 도메인 10개를 보여줌
- 많이 접속한다는 것은 많은 사용자가 접속한다는 뜻이지만 소수의 클라이언트가 많이 접속할 수도 있다는 뜻이기도 함

  (예) 동일한 도메인을 10분 동안 60번씩 요청할 경우, 자동화된 프로그램으로 동작한다고 추측 가능
- **네트워크 접속 행위를 분석 시 해당 트래픽이 사용자가 발생시킨 것인지, 자동 프로그램이 일으킨 행위인지를 분석의 기준으로 삼으면 좋음**

* 현황분석은 숫자를 보여주지만, 해당 숫자를에서 이상 징후 유추 가능

```
index=dnslog sourcetype=dnslog dpt=53 domain!="*.arpa" domain!="-"
| eval list="mozilla"
| `ut_parse(domain,list)`
| top showperc=f limit=10 ut_netloc
```

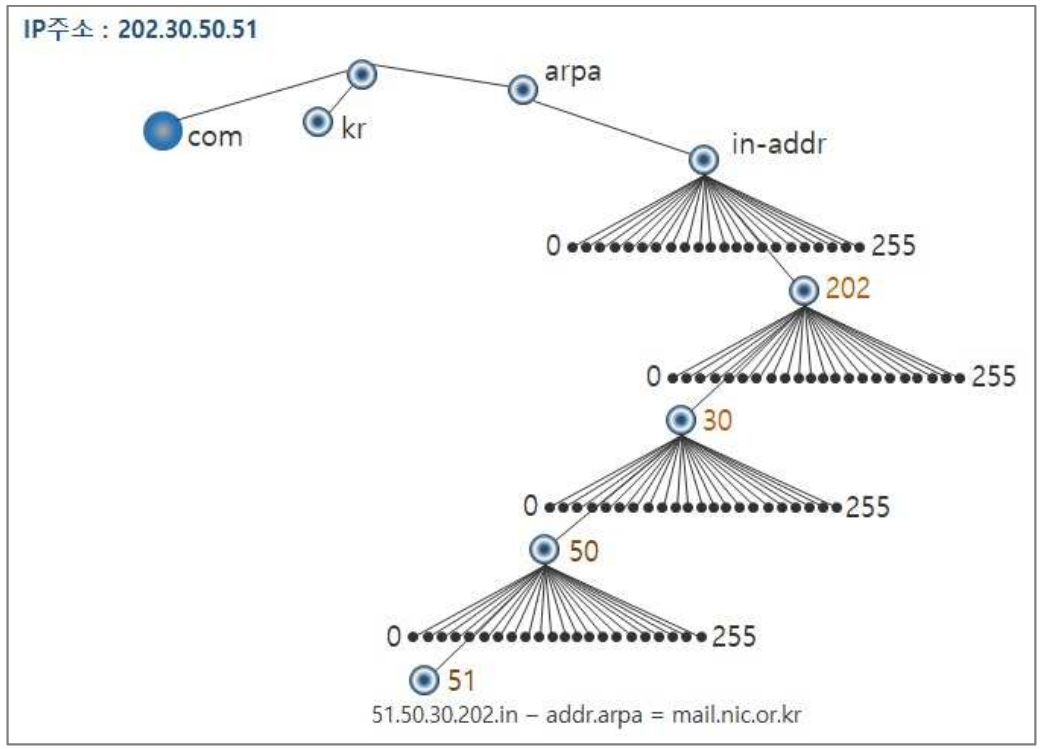
ut_netloc	count
teredo.ipv6.microsoft.com	47565
gms.ahnlab.com	713
crl.microsoft.com	564
google.com	563
ctldl.windowsupdate.com	520
www.microsoft.com	194
s-iavs9x.avcdn.net	190
s-avi18.avcdn.net	172
tus1gwynwapex01.symantec.com	153
tags.baikalize.com	142

domain!="*.arpa" domain!="-"	Reverse 도메인 또는 Domain필드가 없는 경우는 제외

Reverse Domain (Inverse domain 또는 PTR recode)

- 역방향 조회: IP주소에 대응하는 도메인 이름 조회
- IP주소에 해당하는 숫자와 특수 문자열 in-addr.arpa로 구성

(예) 51.50.30.202.in-addr.arpa



top showperc=f limit=10 ut_netloc	10개의 도메인을 추출 Showperc=f 데이터가 점유하는 비율을 숨김
eval list="mozilla" `ut_parse(domain,list)`	TLD 목록을 mozilla에서 지정한 형식을 따른다는 것을 의미 Domain은 도메인 값이 지정한 필드명

최상위 도메인(**Top-level domain, TLD**)

- 도메인 네임의 가장 마지막 부분 (예) www.sks.com 의 TLD는 .com
- TLD는 일반 최상위 도메인(.com)와 국가 코드 최상위 도메인(kr)로 나뉨

<<URL Toolbox가 지원하는 매크로>>

ut_netloc : 전체 도메인을 보여줌

ut_domain : 서브도메인을 제외한 도메인 명을 보여줌

ut_subdomain : 서버 도메인만 보여줌

ut_tld: 도메인에서 utl값만 보여줌

서브도메인(subdomain)
- 도메인 소유자가 생성하는 도메인명

```
index=dnslog sourcetype=dnslog domain!="-"
| eval list="mozilla"
| `ut_parse(domain,list)`
| table ut_netloc, ut_domain, ut_subdomain, ut_domain, ut_domain_without_tld, ut_tld
| dedup ut_netloc
```

ut_netloc
전체 도메인

ut_domain
서브도메인을
제외한 도메인 명

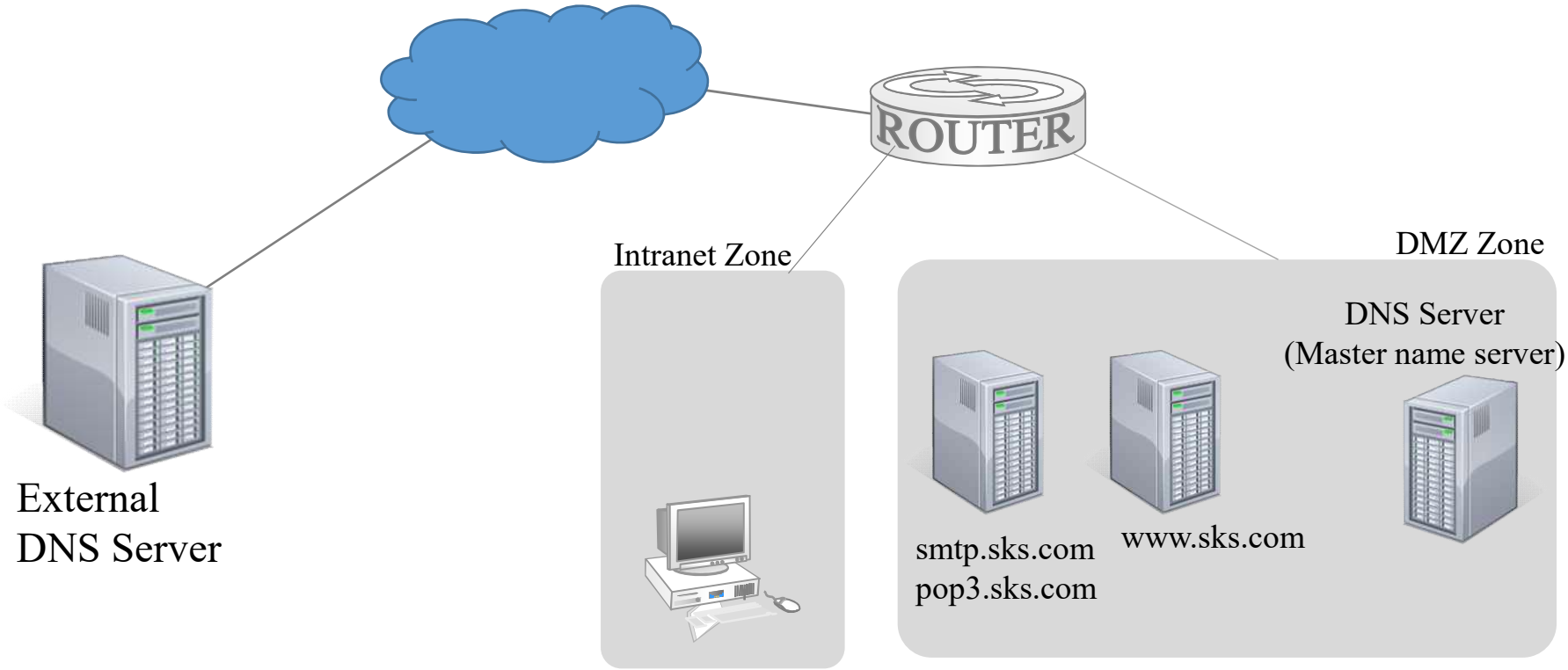
ut_subdomain
서브 도메인

ut_tld
도메인에서
utl값만 보여줌

ut_netloc	ut_domain	ut_subdomain	ut_domain_without_tld	ut_tld
teredo.ipv6.microsoft.com	microsoft.com	teredo.ipv6	microsoft	com
bambooroot.s3.amazonaws.com	amazonaws.com	bambooroot.s3	amazonaws	com
crl.microsoft.com	microsoft.com	crl	microsoft	com
ctldl.windowsupdate.com	windowsupdate.com	ctldl	windowsupdate	com
nexus.officeapps.live.com	live.com	nexus.officeapps	live	com
fe2.update.microsoft.com	microsoft.com	fe2.update	microsoft	com
download.microsoft.com	microsoft.com	download	microsoft	com
www.microsoft.com	microsoft.com	www	microsoft	com
ds.download.windowsupdate.com	windowsupdate.com	ds.download	windowsupdate	com
gms.ahnlab.com	ahnlab.com	gms	ahnlab	com

내부망 DNS 서버

- 인터넷으로 향하는 도메인과 내부망으로 향하는 도메인을 구분해서 분석해야 함
- 내부망 도메인은 기업이나 조직에서 사용하는 도메인
- 내부용 DNS서버는 내부 사용자가 인터넷 또는 내부 업무망을 접속 사용



- 내부 도메인의 집중 질의
  - 공격자가 내부는 탐색하는 lateral movement 공격일 수 있음
  - 감염됨 PC가 인터넷이 위치하는 C2서버 접속을 위한 준비일 수도 있음
- 보안 담장자는 인터넷으로 향하는 도메인과 내부망으로 향하는 도메인을 구분해서 분석해서 네트워크 접속 유형을 파악

Lateral movement

- 내부망 공격이라 부름
- 조직 내부로 침투한 위협이 최종 타깃 시스템을 찾기 위해 내부망에서 이동하는것
- 횡적이동: Client to Client 또는 Server to Server 이동
- 종적이동: Clietn to Server 또는 Server to Client
- 주위 시스템을 감염시키는 것이 목표

내부 서버 도메인을 조회하는 현황 파악

```
index=dnslog sourcetype=dnslog dpt=53 domain!="*.arpa" domain!="-"
| eval list="mozilla"
| `ut_parse(domain,list)`
| where math(ut_domain, “sks.com$")
| top showperc=f ut_netloc
```

❷ Top 10 도메인 요청 IP 현황

- 여러 명이 조회해서 조회 숫자가 많은 도메인과 한 명이 집중해서 조회한 도메인 구분
- 도메인과 해당 도메인을 접속한 송신지 IP주소를 동시에 검색

```
index=dnslog sourcetype=dnslog dpt=53 domain!="*.arpa" domain!="-"
| eval list="mozilla"
| `ut_parse(domain,list)`
| top showperc=f src, ut_netloc
```

src	ut_netloc	count
172.16.146.107	teredo.ipv6.microsoft.com	35199
172.16.138.48	teredo.ipv6.microsoft.com	12366
172.16.138.48	gms.ahnlab.com	699
172.16.146.107	ctldl.windowsupdate.com	513
172.16.146.107	crl.microsoft.com	469
172.16.146.107	www.microsoft.com	194
172.16.146.107	tus1gwynwapex01.symantec.com	153
172.16.158.111	tags.baikalize.com	133
172.16.138.48	bambooroot.s3.amazonaws.com	107
172.16.138.48	nexus.officeapps.live.com	102

❸ 도메인 응답코드 현황

- 도메인 응답코드(reply code)는 사용자가 요청한 도메인을 DNS서버가 응답한 결과 값
- Zeek의 응답코드 필드는 rcode와 rcode_name

rcode	rcode_name	설명
0	NoError	오류없음
1	FormErr	Query 형식 오류
2	SevFail	DNS 서버 자체의 문제로 실패
3	NXDomain	사용자가 질의한 도메인명이 존재하지 않음 Non-eXistent Domain
4	Notlmp	DNS 서버가 해당 질의를 지원하지 않음
5	Refused	정책적인 이유로 질의를 거절함

- NXDomain 또는 Refused는 사용자가 질의한 도메인이 없다는 것임
- 도메인명을 잘못 입력한 경우 해당 도메인이 등록되지 않은 경우 오류가 발생

  - 지속적인 NXDomain 응답은 점검 대상

- **NXDomain이 지속적으로 발생하는 경우**

  - 감염된 PC가 사라진 도메인의 접속을 시도

  - DGA로 생성된 도메인이 인터넷에 아직 등록되지 않은 경우

  * DGA (Domain Generation Algorithms)

    - 도메인 이름을 주기적으로 동적으로 생성하는 알고리즘

```
index=dnslog sourcetype=dnslog domain!="-" rcode_name= "NXDomain"
| top showperc=f src, domain
```

* NXDomain이 빈번하게 발생하는 도메인과 해당 질의를 발생하는 송신지 모니터링

src	ut_netloc	count
172.16.146.107	teredo.ipv6.microsoft.com	35199
172.16.138.48	teredo.ipv6.microsoft.com	12366
172.16.138.48	gms.ahnlab.com	699
172.16.146.107	ctldl.windowsupdate.com	513
172.16.146.107	crl.microsoft.com	469
172.16.146.107	www.microsoft.com	194
172.16.146.107	tus1gwynwapex01.symantec.com	153
172.16.158.111	tags.baikalize.com	133
172.16.138.48	bambooroot.s3.amazonaws.com	107
172.16.138.48	nexus.officeapps.live.com	102

DNS 이상 징후 분석

❶ 비정상적인 서브 도메일 길이

❷ 비허가 DNS 사용/DNS 터널링

❸ 도메인 엔트로피 값을 이용한 탐지

❶ 비정상적인 서브 도메인 길이

```
index=dnslog sourcetype=dnslog domain!="-"
| where NOT cidrmatch(domain, "0.0.0.0/0")
| eval list="mozilla"
| `ut_parse(domain,list)`
| where not match(ut_domain, "(microsoft.com|akamaized.net|amazonaws.com)$")
| eval sub_len =len(ut_subdomain)
| search sub_len > 20
| table ut_domain, ut_subdomain, sub_len, ut_netloc
```

```
index=dnslog sourcetype=dnslog domain!="-"
| where NOT cidrmatch(domain, "0.0.0.0/0")
```

- 도메인 필드 값이 IP주소가 아닌 로그 탐색

```
| where not match(ut_domain, "(microsoft.com|akamaized.net|amazonaws.com)$")
| eval sub_len =len(ut_subdomain)
| search sub_len > 20
```

- ut_domain 필드 값이 microsoft.com 또는 akamaized.net, amazonaws.com로 끝나지 않는 로그 검사
- 클라우드 서비스의 서브 도메인의 길이가 길기 때문

- 도메인 응답코드(reply code)는 사용자가 요청한 도메인을 DNS서버가 응답한 결과 값
- Zeek의 응답코드 필드는 rcode와 rcode_name

```
index=dnslog sourcetype=dnslog domain!="-"
| where NOT cidrmatch(domain, "0.0.0.0/0")
| eval list="mozilla"
| `ut_parse(domain,list)`
| where not match(ut_domain, "(microsoft.com|akamaized.net|amazonaws.com)$")
| eval sub_len =len(ut_subdomain)
| search sub_len > 20
```

❷ 비허가 DNS 사용/DNS 터널링

- 직접 공격보다는 비정상적인 네트워크 행위를 탐지
- 호스트가 내부망에서 지정한 DNS서버가 아닌 임의의 DNS서버에 질의를 전송하는 증상
- 전제 조건
  - 기업 내부망에 전용 DNS 서버 구축
  - 내부 클라이언트나 서버가 반드시 내부망 NDS 서버를 사용하도록 강제

```
index=dnslog sourcetype=dnslog (dst!="172.16.142.11" AND dst!="172.16.142.12")
(src !="172.16.142.11" AND src!="172.16.142.12")
| stats count by dst
| sort – count
```

- 목적지가 DNS 서버가 아닌 것과 출발지가 DNS서버가 아닌것을 추출
- 출발지가 내부 DNS 서버가 아니도 도메인 질의 대상이 내부 지정 DNS서버가 아닌 내부망 호스트는 비정상 접속시도로 판별

❸ 도메인 엔트로피 값을 이용한 탐지

- 엔트로피는 정보의 양을 측정하는 방식
  - 자주 발생하지 않은 사건은 정보량이 많다는 것을 기반함
- 확률 계산 결과 값이 크면 정보량이 많은 것이고 작으면 적은 것
  - 자주 발생하지 않은 사건은 정보량이 많음
  - 자주 발생하는 일은 정보량이 적음
- 익숙한 단어들로 만들어진 도메인은 정보량이 적음 (엔트로피 값이 작다)
- URL toolbox의 ut_Shannon() 매크로를 이용해서 엔트로피 계산

| `ut_shannon(ut_netloc)` 지정된 도메인의 엔트로피 값을 계산

```
index=dnslog sourcetype=dnslog domain!="-"
|where NOT match(domain,
"(microsoft.com|akamaized.net|amazonaws.com|addr.|qoo19.jp)$")
| eval list="mozilla"
| `ut_parse(domain,list)`
| `ut_shannon(ut_netloc)`
| eval shannon =round (ut_shannon,2)
| where shannon > 3.9
| eval shannon_str = ut_netloc."/".shannon
| stats count by ut_domain, shonnon_str
|stats list(sahnnon_str) by ut_domain
```